

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

Supervisor:
Dr. Bui Van Hieu
Dr. Dang Van Hieu

Abstract

In the modern cybersecurity landscape, Security Operations Centers (SOCs) face mounting pressure to automate the triage and response of an ever-increasing volume of security alerts; yet every available solution entails a significant trade-off. Conventional automation tools operate through rigid, pre-scripted playbooks that can neither reason about ambiguous situations nor justify their decisions, whereas feeding raw logs directly to a Large Language Model (LLM) proves too slow for real-time operation, exposes the system to manipulation through the log content itself, and violates data-sovereignty requirements when deployed in the cloud. To overcome these limitations, this thesis proposes SENTINEL, a two-tier cognitive architecture for automated threat detection and response. The first tier is a fast, deterministic filter that instantly discards the majority of benign traffic and forwards only the genuinely suspicious minority to the second tier: a locally hosted artificial-intelligence agent that reasons over authoritative security knowledge sources (MITRE ATT&CK techniques and NIST incident-response guidance) and operates behind multiple protective guardrails to withstand deception by malicious inputs.

Evaluated on standard intrusion-detection datasets, SENTINEL demonstrates that AI-based reasoning can remain practically viable: by reserving this costly computation for the small fraction of alerts that genuinely warrant it, the system reduces average response latency by more than 80% relative to an LLM-only approach. It further withstands content-based manipulation attacks, produces transparent and verifiable justifications for each decision, and runs entirely on local, consumer-grade hardware without transmitting any data off-site. Taken together, these findings affirm that pairing a high-speed deterministic filter with a secure, transparent, and locally deployed AI reasoning tier constitutes a practical and trustworthy approach to automating modern network defence.

Acknowledgments

First and foremost, I would like to express my deepest and most sincere gratitude to my academic supervisors, Dr. Bui Van Hieu and Dr. Dang Van Hieu. Their precise scientific guidance, profound professional insight, and patient, dedicated mentorship throughout the course of this research have been the solid foundation upon which this thesis was brought to completion.

I am also profoundly grateful to the faculty and staff of the FSB School of Business and Technology, FPT University, who equipped me with an invaluable foundation of academic knowledge and cultivated a professional, modern learning and research environment, affording every possible support to students throughout the Master's programme.

My sincere appreciation likewise goes to the leadership and my colleagues at Department C12, the National Data Center, where I am currently employed. Their accommodation of my time, the practical working environment they provided, and their valuable professional exchanges were a continual source of motivation, enabling me to fulfil both my professional responsibilities and my academic pursuits.

Finally, and most importantly of all, I dedicate my heartfelt gratitude to my beloved family, especially my dear wife and our young child. Their silent sacrifices, patience, understanding, and unwavering moral support during the long months I devoted to intensive experimentation have been my greatest source of strength, steadying my every step on this journey toward the Master's degree.

List of Figures

Figure 1.	Holistic SENTINEL architecture: two-tier data flow and structural components. (Source: Author)	20
Figure 2.	Detailed runtime execution flow within the SENTINEL pipeline. (Source: Author)	21

List of Tables

Table 1.	Quantization levels for the Gemma-2-9B model (approximate). (Source: Author)	15
Table 2.	LLM cognitive vulnerabilities and SENTINEL’s mitigations. (Source: Author)	16
Table 3.	Comparative analysis of SENTINEL against recent agentic-AI security frameworks (✓ supported; ~ partial; × absent; – N/A). (Source: Author)	18
Table 4.	State-transition matrix of the Tier-2 cognitive agent FSM. (Source: Author)	24
Table 5.	Retrieval paradigms in the hybrid search strategy. (Source: Author)	25
Table 6.	Threat Memory database schema. (Source: Author)	26
Table 7.	Representative mapping of principal CSE-CIC-IDS2018 attack families to MITRE ATT&CK techniques and default actions. (Source: Author)	30
Table 8.	Tier-1 binary classification on the Unified Stream (CIC-IDS-labelled events). (Source: Author)	31
Table 9.	ML gateway (LightGBM) classification and LLM offload. Classification is on the 3,204-sample <code>datatest</code> ; offload (Config G) is on the 1,250-sample <code>ground_truth</code> . (Source: Author)	32
Table 10.	Tier-2 adjudication on 800 escalated events (ML gateway bypassed; per-event full pipeline). (Source: Author)	32
Table 11.	Emergent multi-stage APT detection on DAPT2020 chains (clean memory). (Source: Author)	33
Table 12.	Graded zero-day detection boundary vs. injected single-feature deviation (Tier-1 only, $n = 210/\text{level}$). (Source: Author)	34
Table 13.	Controlled balanced ablation (150 benign + 150 attack). The pure-LLM baseline over-flags; the gated configurations (C–F) are verdict-identical. (Source: Author)	35
Table 14.	Welford threshold sensitivity on the real mixed stream (Tier-1 only). (Source: Author)	35
Table 15.	Static guardrail-layer block rate against the 120-payload suite. (Source: Author)	36
Table 16.	Cross-family LLM-as-Judge reasoning quality (Llama-3-8B judge, Gemma-2-9B agent, $n = 908$, 1–5 scale). (Source: Author)	37
Table 17.	Consolidated results across the five evaluation dimensions. (Source: Author)	38

List of Abbreviations

Abbreviation	Full Description
APT	Advanced Persistent Threat
CTI	Cyber Threat Intelligence
DAPT	Dynamic/Delayed Advanced Persistent Threat
FAISS	Facebook AI Similarity Search
GGUF	GPT-Generated Unified Format
HITL	Human-in-the-Loop
LLM	Large Language Model
RAG	Retrieval-Augmented Generation
RRF	Reciprocal Rank Fusion
SIEM	Security Information and Event Management
SOC	Security Operations Center

Contents

Abstract	1
Acknowledgments	2
List of Abbreviations	5
1 Introduction	8
1.1 Background and Motivation	8
1.2 Research Objectives	9
1.3 Research Questions	10
1.4 Scope and Object of Study	11
1.5 Research Methodology	11
1.6 Contributions of the Thesis	12
1.7 Structure of the Thesis	13
2 Theoretical Background and Literature Review	14
2.1 SOCs and the Cognitive Bottleneck	14
2.2 Local LLMs and the Mathematics of Quantization	14
2.3 Agentic AI and State-Graph Models	15
2.4 Retrieval-Augmented Generation and Hybrid Search	15
2.5 LLM Cognitive Vulnerabilities and Adversarial Vectors	16
2.6 Online Statistical Anomaly Detection: Welford’s Algorithm	16
2.7 Related Work: Agentic AI for Security Operations	17
2.8 Chapter Summary	18
3 System Design and Technical Implementation	19
3.1 Overview of the Two-Tier Cognitive Architecture	19
3.2 Positioning within the Existing SOC Stack	22
3.3 Tier-1: Stateless Wire-Speed Filter (RuleEngine & Welford)	22
3.4 ML Gateway: Learned Tier-1 Load Shedding	23
3.5 Tier-2: LangGraph Stateful Cognitive Agent	24
3.6 Dual-RAG Mechanism and Semantic Memory	25
3.7 Threat Memory and APT Campaign Correlation	25
3.8 AI Security Guardrails and Encapsulation	26
3.9 Data Integrity and HMAC Protection	27
3.10 Dashboard, Deployment, and Scalability	27
3.11 Chapter Summary	28
4 Experiments and Evaluation	29
4.1 Experimental Environment and Datasets	29

4.2	5D Metrics and Ablation Design	30
4.3	Classification Accuracy on the Unified Stream	31
4.4	ML Gateway: Learned Tier-1 Load Shedding	31
4.5	Tier-2 Escalation Adjudication	32
4.6	Emergent Multi-Day APT Correlation (Foundational)	33
4.7	Signature-less (Zero-Day) Escalation via Welford Scoring	33
4.8	Ablation: Two-Tier Latency Trade-off and Balanced Comparison	34
4.9	Adversarial Robustness (Security)	36
4.10	Integrity and Reasoning Quality (LLM-as-a-Judge)	36
4.11	Operational Robustness	37
4.12	Structured ATT&CK Mapping	37
4.13	Summary of 5D Results	38
4.14	Chapter Summary	38
5	Conclusion and Future Work	40
5.1	Synthesis of Achieved Research Results	40
5.2	Scientific and Practical Contributions	41
5.3	Existing Limitations	42
5.4	Future Development Directions	43
	References	45

Chapter 1

Introduction

This chapter establishes the research framework for SENTINEL, a two-tier cognitive architecture that automates threat detection and incident response in modern Security Operations Centers (SOCs). By analysing alert fatigue, deterministic rule blindness, and the computational constraints of Large Language Models (LLMs), it details the design and validation of a secure hybrid detection pipeline, delineating the objectives, research questions, scope, and quantitative methodology.

1.1 Background and Motivation

The transition towards cloud-native architectures in modern enterprise environments has substantially broadened the potential attack surface. Threat actors now employ a spectrum of techniques ranging from ubiquitous malware to highly orchestrated, multi-stage operations [2]. Despite this diversity, defenders consistently face a unified challenge: the overwhelming volume of security telemetry. Security Operations Centers (SOCs) centralise data from Next-Generation Firewalls (NGFWs), Intrusion Detection/Prevention Systems (IDS/IPS), and Endpoint Detection and Response (EDR) solutions into Security Information and Event Management (SIEM) platforms to facilitate normalisation and correlation [3]. However, conventional front-line mechanisms, such as wire-speed IDS/IPS, remain inherently deterministic. While effective at volume reduction, they lack the capacity to reason about ambiguous signals or provide contextual explanations. Consequently, the sheer velocity of data engenders a “Big Data Paradox” [4], disproportionately shifting the cognitive burden of contextual judgment onto human analysts. This structural imbalance culminates in *alert fatigue*, wherein operators are inundated with high volumes of low-fidelity, predominantly false-positive notifications [6], thereby elevating the probability that critical intrusions are inadvertently ignored.

This operational bottleneck is exacerbated by two fundamental gaps. Primarily, traditional signature-based filtration systems [2] exhibit structural blindness toward novel attack

vectors, such as zero-day exploits and polymorphic variants, which routinely circumvent static rules through trivial payload obfuscation. This highlights an urgent requirement for signature-independent, statistical anomaly detection. Furthermore, economic constraints often dictate log sampling, which inadvertently disrupts the temporal continuity requisite for reconstructing low-and-slow Advanced Persistent Threat (APT) campaigns [5]. Conventional Security Orchestration, Automation, and Response (SOAR) platforms fail to bridge this reasoning deficit, as they rely on rigid, pre-defined playbooks incapable of adaptive reasoning or explaining unscripted anomalies [7].

Large Language Models (LLMs) offer the sophisticated contextual reasoning necessary to address these shortcomings; nevertheless, their direct deployment within live SOC environments introduces a multifaceted integration paradox. The quadratic computational complexity inherent to the self-attention mechanism [20] renders their inference latency prohibitive for high-velocity telemetry streams. Additionally, the natural-language nature of LLM interfaces creates severe vulnerabilities to log-substrate prompt injections. In such scenarios, adversarial payloads embedded within seemingly innocuous fields (e.g., HTTP User-Agent) can hijack the model’s cognitive processes unless rigorous isolation is enforced [11]. Finally, stringent data sovereignty and Zero-Trust mandates [35] often prohibit the exfiltration of sensitive telemetry to external cloud services, thereby necessitating that any reasoning engine operate strictly on-premises. To navigate these constraints, this research proposes SENTINEL: a cognitive, dual-tier architecture. It comprises a stateless Tier-1 statistical filter operating at wire-speed, augmented by a learned machine learning (ML) gateway that autonomously resolves the confident majority of escalations. This is seamlessly integrated with a secure, locally hosted Tier-2 Agentic AI tier dedicated to cognitively isolated, high-level reasoning. As an emergent consequence of its stateful orchestration, the design inherently preserves temporal event chains and detects signature-less outliers, establishing a robust foundation for next-generation automated defence.

1.2 Research Objectives

The overarching objective of this thesis is to design, implement, and quantitatively evaluate the SENTINEL architecture, a two-tier cognitive system that synergises low-latency statistical filtration with secure, context-aware agentic reasoning. To realise this, the research pursues three specific objectives:

First, to engineer a dual-stage filtration pipeline (**Tier 1**) that mitigates alert fatigue at the ingestion layer. This involves implementing a wire-speed deterministic filter leveraging Welford’s online algorithm for $O(1)$ rolling variance and Z-score computation, sequentially coupled with a learned Machine Learning (ML) gateway (LightGBM). The primary goal is to maximise the autonomous resolution of confident escalations, thereby drastically

reducing the invocation frequency of the computationally expensive LLM inference engine while maintaining measurable detection accuracy.

Second, to architect secure, structural encapsulation mechanisms for the integration of a local, quantised LLM (**Tier 2**). This necessitates the design of deterministic, construction-based defences—specifically Delimited Data Encapsulation utilizing cryptographic nonces (e.g., «<DATA_HASH . . . >>»), a bi-tier consensus guardrail, output sanitisation, and an HMAC-chained audit trail. The objective is to neutralise adversarial vectors, such as log-substrate prompt injections, through architectural guarantees rather than relying on brittle, training-dependent semantic classifiers.

Third, to construct a stateful cognitive orchestration framework leveraging LangGraph, integrating a persistent Threat Memory and a dual retrieval-augmented grounding subsystem. By fusing dense semantic search with sparse keyword matching (MITRE ATT&CK and NIST SP 800-61r2) via Reciprocal Rank Fusion, this objective aims to robustly ground the agent’s forensic attributions and justifications, whilst enabling the emergent correlation of multi-day campaigns derived from accumulated state.

1.3 Research Questions

The empirical validation of the proposed architecture is directed by three central research questions, each corresponding directly to the aforementioned objectives:

RQ1 (Filtration Economics): How can a hybrid pipeline—comprising an $O(1)$ deterministic filter based on online statistical baselines and a subsequent learned ML gateway—effectively absorb high-velocity SOC telemetry prior to invoking multi-second local LLM inference, and what is the quantifiable trade-off regarding detection accuracy? This question emphasizes the architectural value of operationalizing a local LLM by offloading the majority of processing to faster, specialized components.

RQ2 (Architectural Defence Boundaries): Within the architecture, where is defence against log-substrate injection most effectively situated, and how do the capabilities of deterministic pattern filtration contrast with Delimited Data Encapsulation and two-tier consensus guardrails? Specifically, which adversarial vectors are neutralised by each respective layer, and how does this structural approach secure the cognitive tier against downgrade attacks?

RQ3 (The Efficacy of Statefulness): What specific capabilities are enabled by transitioning from rigid Runbook Automation to a stateful agentic framework equipped with persistent Threat Memory and dual-retrieval mechanisms? This is measured by evaluating (a) the emergent capacity to correlate multi-day campaigns without prior explicit temporal rules, and (b) the precision of MITRE ATT&CK technique attribution alongside the

fidelity of the generated justifications.

Note on Instrumentation. RQ3 intentionally refrains from employing binary classification accuracy as a metric for assessing the contribution of knowledge retrieval. The retrieved context fundamentally influences the *attribution* and *justification* of a verdict rather than the binary determination of maliciousness. Applying binary accuracy in this context would constitute a methodological mismatch. Similarly, this thesis does not claim the LLM tier functions as a primary classifier; empirical evidence positions it as a coverage-biased safety net for complex reasoning, a limitation explicitly acknowledged in Chapter 5.

1.4 Scope and Object of Study

Object of Study: The primary subject of this research is the two-tier cognitive architecture itself. This encompasses the precise mechanisms through which a stateless, wire-speed Tier-1 statistical filter and a learned gateway are orchestrated alongside a stateful, locally hosted Tier-2 agentic framework to automate SOC detection and incident response. This includes high-velocity OSI Layer 3–4 flow telemetry (specifically, the NetFlow five-tuple and CICFlowMeter features, utilizing PCAP metadata in lieu of Deep Packet Inspection); stateful agent orchestration via LangGraph; the execution of air-gapped inference using local quantised LLMs; and the mitigation of adversarial vectors such as log-substrate injection, delimiter smuggling, and knowledge-base poisoning.

Scope: The empirical evaluation is strictly constrained to the CSE-CIC-IDS2018 dataset [1] for broad attack classification, and the DAPT2020 dataset [29] for multi-stage APT correlation. Zero-day threats are simulated by injecting extreme Welford statistical deviations into verified benign flows. The reasoning engine is standardized on a locally hosted *Gemma-2-9B-IT* model, quantised to the Q6_K format via `llama.cpp`, executing on a single consumer-grade GPU to strictly enforce data sovereignty. Furthermore, autonomous response capabilities are limited to the generation of firewall policies, forensic reporting, and structural attributions; automated physical network disconnection is explicitly excluded from the current scope.

1.5 Research Methodology

This thesis adopts a Design Science Research (DSR) methodology, underpinned by deductive and quantitative reasoning. It generates novel knowledge by constructing a functional artifact (SENTINEL) and rigorously evaluating its performance against real-world operational challenges, ensuring all theoretical claims are empirically substantiated. The rea-

soning framework operates across three dimensions: statistical (delineating normal traffic baselines from anomalies), logical (formalising the agent’s decision-making state-graph), and adversarial (stress-testing systemic resilience against manipulation).

Practically, the architecture is implemented as a functional two-tier prototype. It undergoes end-to-end evaluation by replaying archived datasets and simulated live traffic, specifically introducing adversarial payloads to assess robustness. The system is evaluated across a comprehensive five-dimensional framework: Accuracy, Performance, Security, Explainability, and Integrity. Controlled ablation studies are employed to systematically isolate the contribution of individual components, while non-parametric statistical tests (e.g., McNemar’s and Mann–Whitney U) confirm the statistical significance of observed architectural variations. The evaluation synthesises quantitative metrics (e.g., latency, F1-scores) with qualitative outputs (the model’s forensic justifications). To prevent self-aggrandisement bias, qualitative reasoning is objectively scored utilizing an automated RAGAS-inspired framework [30] administered by an independent, cross-family LLM judge, ensuring a rigorous, comparative assessment.

1.6 Contributions of the Thesis

The contributions of this research are tri-fold, each strictly delineated by the supporting empirical evidence.

Architecturally, the thesis validates a hybrid two-tier pipeline that successfully resolves the latency bottlenecks associated with locally hosted, multi-second LLMs in operational SOC. The primary contribution is the *compositional integration*: a stateless $O(1)$ statistical filter combined with a learned LightGBM gateway that autonomously sheds 83.8% of confident escalations at wire-speed. Furthermore, an in-memory Semantic Cache (Tier-1.75) resolves recurring alerts in approximately 1 ms. This ensures the network is protected deterministically, reserving the computationally intensive cognitive tier exclusively for the ambiguous minority of anomalous events.

In AI Security, the research contributes a deterministic, structurally robust defence mechanism against log-substrate prompt injections. By employing Delimited Data Encapsulation utilizing cryptographic nonces (e.g., «<DATA_HASH . . .>»), a deterministic Tier-1/Tier-2 consensus guardrail, and an HMAC-chained audit trail, the system provides security guarantees that hold by architectural construction rather than probabilistic training. This ensures that the fixed-rule consensus guard cannot be persuasively bypassed, effectively neutralizing both syntactic and semantic downgrade attempts.

In Orchestration, the architecture supersedes rigid Runbook Automation with a stateful, acyclic, and tool-free state-graph orchestrated on a single local quantised model. This

yields a response tier that is highly adaptive, yet strictly reproducible and forensically auditable, entirely within the constraints of strict data sovereignty. Additional foundational capabilities enabled by this architecture—namely, signature-less anomaly escalation via statistical baselining and emergent multi-day APT correlation from persistent state—are presented as bounded proofs of concept, laying the groundwork for future production-scale maturation.

1.7 Structure of the Thesis

Chapter 2 establishes the theoretical foundations, including LLM quantization, state-graph models, hybrid RAG, online statistics, and reviews related agentic-security literature. Chapter 3 details the technical system design: the two-tier filter, the ML gateway, the stateful agentic Finite State Machine (FSM), hybrid retrieval, structural guardrails, the dashboard, and deployment configurations. Chapter 4 presents the empirical experiments, controlled ablation studies, and non-parametric statistical validation. Finally, Chapter 5 synthesises the findings, acknowledges existing limitations, and outlines future research trajectories.

Chapter 2

Theoretical Background and Literature Review

This chapter establishes the theoretical foundations for SENTINEL, beginning with the cognitive bottleneck in modern Security Operations Centers (SOCs), then covering local Large Language Models (LLMs) and quantization, state-graph Agentic AI, Retrieval-Augmented Generation (RAG), adversarial AI vulnerabilities, online statistical anomaly detection, and related agentic-security work.

2.1 SOCs and the Cognitive Bottleneck

Modern SOCs consolidate diverse telemetry (NGFW, EDR, IDS/IPS) into centralised SIEM platforms [3] to identify threats and escalate incidents to analysts. However, the shift to cloud-native infrastructure has caused a vast expansion of log data [4], driving the *alert-fatigue* crisis: Tier-1 analysts are routinely overwhelmed by thousands of daily alerts, mostly false positives, and continuous alert floods deplete attentional resources and systematically increase the probability of critical oversight [6]. Compounding this, Advanced Persistent Threats (APTs) employ stealthy, prolonged tactics that stateless rule-based frameworks cannot correlate across long temporal horizons [5].

2.2 Local LLMs and the Mathematics of Quantization

Transformer-based LLMs offer promising automation: the self-attention mechanism weighs every token against all others in parallel [20], capturing the long-range dependencies needed to correlate events across an extended log stream. However, data-sovereignty requirements forbid transmitting sensitive telemetry to external cloud endpoints under zero-trust guidelines [35], mandating *local* LLMs in air-gapped environments. Running multi-billion-parameter models locally is memory-bound: a 9B model such as *Gemma-2-9B-IT* in FP16 needs ≈ 18 GB of VRAM. Quantization re-maps the continuous high-precision weights onto a coarser grid of lower-bit integers, trading a controlled loss of precision for large

memory savings [21]. Via GGUF and the Q6_K standard in `llama.cpp`, the footprint drops to $\approx 7\text{--}8$ GB (over 50% reduction) with near-lossless reasoning (Table 1), enabling inference on consumer hardware.

Table 1. Quantization levels for the Gemma-2-9B model (approximate). (Source: Author)

Format	Bits / weight	VRAM	Quality
FP16 (baseline)	16	≈ 18 GB	Reference
Q6_K (this work)	≈ 6.6	$\approx 7\text{--}8$ GB	Near-lossless
Q4_K_M	≈ 4.5	$\approx 5\text{--}6$ GB	Minor degradation

2.3 Agentic AI and State-Graph Models

Automated security is shifting from rigid Runbook Automation (RBA) toward autonomous Agentic AI [7]. RBA relies on static, pre-defined scripts for linear alert handling—efficient but structurally blind to zero-day conditions and polymorphic formats. Agentic systems exhibit cognitive autonomy (self-reflection, multi-step planning, adaptive routing), adjusting their analysis in response to intermediate findings. Such agents are modelled as stateful directed graphs functioning as finite state machines [10], where nodes are computational or cognitive actions and conditional edges enforce dynamic routing on parent outputs. Stateful orchestration lets agents retain working memory across events; although this paradigm also permits cyclic re-analysis within one event, SENTINEL deliberately adopts an *acyclic* per-event traversal for determinism and auditability, persisting cross-event state in Threat Memory rather than looping.

2.4 Retrieval-Augmented Generation and Hybrid Search

The primary LLM limitation is factual hallucination, a severe risk of misconfiguration in automated SOC. RAG counters it by conditioning each response on freshly retrieved passages from an authoritative corpus rather than parametric memory alone [9], narrowing the space for unsupported claims. Modern RAG uses a *hybrid* strategy: dense vector search with embedding models (`all-MiniLM-L6-v2`) [27] and FAISS cosine similarity [22] captures semantic meaning even when keywords differ, while sparse BM25 [23] matches technical identifiers (CVE codes, IPs) via TF-IDF weighting. Reciprocal Rank Fusion [13] consolidates the two ranked lists into one high-precision result by balancing dense semantics against sparse keyword weight.

2.5 LLM Cognitive Vulnerabilities and Adversarial Vectors

Deploying LLMs as core reasoning engines introduces novel vulnerabilities. Because LLMs process natural language without a compile-time separation of code and data, they are vulnerable to instruction hijacking [11]. The most relevant vector is *log-substrate prompt injection* [14]: adversaries embed command payloads in telemetry fields (e.g. User-Agent), and when the LLM processes these logs it may execute the embedded instructions, bypassing controls. Recent work formalises these attacks into a four-class taxonomy [14]: *Direct Override* (S1) instructs the model to ignore prior directives; *Persona Hijack* (S2) coerces an unrestricted persona; *Context Manipulation* (S3) fabricates authorization metadata (e.g. “pre-approved”); and *Obfuscated Payload* (S4) hides instructions via Base64/hex/URL encoding or homoglyphs to evade regex filters. Because these fields are attacker-controlled yet structurally indistinguishable from legitimate evidence, a single-pass LLM cannot reliably separate data from instructions—directly motivating the layered guardrail design of Chapter 3 (Table 2).

Table 2. LLM cognitive vulnerabilities and SENTINEL’s mitigations. (Source: Author)

Attack Vector	Threat Mechanism	Mitigation
Direct Prompt Injection	Instruction-hijack payloads in inputs	Regex pattern filters, structural prompts
Log-Substrate Injection	Instructions in log fields (User-Agent)	Delimited Encapsulation w/ «<DATA_HASH...> nonces
Encoding Bypass	Base64/Hex/URL obfuscation	Multi-layer decoding & normalisation
Delimiter Smuggling	Control markers terminating data scope	Delimiter sanitisation, token budget
Semantic Poisoning	Falsified docs in vector DB	SHA-256 checksum + provenance

2.6 Online Statistical Anomaly Detection: Welford’s Algorithm

Because the quadratic complexity of attention prevents LLMs from analysing raw streams at wire-speed, an $O(1)$ pre-filter is required. Computing rolling baselines over continuous streams needs numerically stable online statistics such as Welford’s algorithm [8], which tracks the running mean and variance without accumulating floating-point error:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad (2.1)$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k), \quad (2.2)$$

$$\sigma_k^2 = \frac{M_{2,k}}{k-1}. \quad (2.3)$$

Maintaining these with constant memory, the system computes a normalised Z-score per packet, rapidly eliminating benign traffic while preserving the event chains of low-and-slow attacks. To validate signature-less detection, a *real-derived* zero-day paradigm isolates a genuine benign flow and drives a single statistic to its extreme boundary, forcing a large Z-score that mimics an unknown outlier and is escalated to Tier-2.

2.7 Related Work: Agentic AI for Security Operations

Automated threat detection evolved through several waves. Classical intrusion detection used machine learning (Random Forests, SVMs) or deep learning (LSTMs, CNNs) [2]; accurate but operating as unexplainable “black boxes.” LLMs then opened a broad research front across cybersecurity, as catalogued by recent systematic reviews [17], motivating a shift toward systems that can explain and act on their findings. Closest to this thesis is a wave of agentic frameworks pairing LLM reasoning with retrieval: CyberRAG [15] orchestrates fine-tuned classifiers through an iterative retrieve-and-reason loop for web-attack labelling; LanG [18] proposes a governance-aware LangGraph platform unifying correlation, LLM rule generation, and attack reconstruction with HITL checkpoints; Sahay et al. [19] couple an autoencoder and deep RL for triage with an LLM for threat hunting inside a SIEM; and multi-agent designs such as AutoBnB-RAG [16] extend retrieval-augmented collaboration to incident response. On the adversarial side, Pandey and Bhujang [14] formalise the log-substrate injection threat (the S1–S4 taxonomy) and demonstrate its effectiveness. These systems establish the value of agentic, retrieval-grounded automation, and most already incorporate a pre-filter and, in some cases, an input guardrail; where they address injection, they tend to rely on a *learned* semantic classifier a novel payload may still evade.

Against this backdrop, SENTINEL differs along three deliberate design axes rather than by a single missing feature. First, its Tier-1 gate is a training-free $O(1)$ Welford statistic (plus a learned *LightGBM* gateway for the escalation band) rather than a pre-filter requiring continual retraining. This is augmented by an in-memory *Semantic Cache* (Tier-1.75) that resolves recurrent alerts in approximately 1 ms, entirely bypassing the LLM. Second, it replaces a learned injection classifier with *deterministic*, structural isolation: Delimited Data Encapsulation utilizing cryptographic «<DATA_HASH...>» nonces, a tier-consensus guard, and an HMAC-chained audit trail. Third, in contrast to tool-calling agents with iterative loops, it adopts an acyclic, tool-free orchestration running entirely on one local quantised model, prioritising determinism, auditability, and data sovereignty. Ta-

ble 3 positions SENTINEL across the capabilities most relevant to a deployable, security-hardened SOC engine.

Table 3. Comparative analysis of SENTINEL against recent agentic-AI security frameworks (✓ supported; ∼ partial; × absent; – N/A). (Source: Author)

Capability	SENTINEL	Cyber-RAG	LanG	Splunk-LLM	Watch-tower
Wire-speed $O(1)$ pre-filter	✓	×	×	∼	–
Semantic Cache (Tier-1.75)	✓	×	×	×	–
Deterministic anti-injection guardrails	✓	×	∼	×	–
Local / air-gapped inference	✓	∼	∼	×	–
Multi-day APT correlation	✓	×	✓	∼	–
Hybrid dense+sparse RAG (RRF)	✓	∼	×	×	–
Tamper-evident HMAC audit	✓	×	∼	×	–

SENTINEL is thus distinguished not by any single component but by their integration: a deterministic Tier-1 filter and learned gateway absorb the high-velocity majority at wire-speed, while a cognitively isolated Tier-2 agent reasons behind cryptographic guardrails, directly addressing the latency–security trade-off the surveyed frameworks leave open.

2.8 Chapter Summary

This chapter established SENTINEL’s foundations: the SOC cognitive bottleneck, local-LLM quantization, stateful agent orchestration, hybrid RAG via RRF, the log-substrate injection taxonomy (S1–S4), and Welford’s $O(1)$ algorithm for signature-less anomaly detection. A comparison against recent agentic-security frameworks positioned SENTINEL as the approach that unifies wire-speed statistical pre-filtering, Tier-1.75 semantic caching, deterministic anti-injection guardrails, local data sovereignty, and tamper-evident auditing. Chapter 3 details the technical design.

Chapter 3

System Design and Technical Implementation

This chapter details the architecture, mathematical formulations, and implementation of the SENTINEL two-tier cognitive security framework: a hybrid detection-and-response pipeline engineered to bridge the gap between wire-speed packet processing and resource-intensive LLM reasoning, while establishing cognitive guardrails that isolate the LLM from adversarial manipulation. It covers the system block diagram, the online statistical pre-filter, the ML gateway, the state-graph cognitive workflow, Dual-RAG retrieval, the Threat Memory schema, the guardrail pipeline, the HMAC audit log, the Streamlit UI, and the Docker deployment.

3.1 Overview of the Two-Tier Cognitive Architecture

To protect enterprise environments without prohibitive latency, SENTINEL splits the pipeline into two specialised tiers (Figure 1). **Tier-1**, a stateless wire-speed layer, sits at the network boundary: it ingests high-velocity telemetry and either computes real-time statistical deviations via Welford’s algorithm or applies regex signatures, dropping or logging benign events instantly. **Tier-2**, a stateful cognitive layer driven by an autonomous LangGraph agent [10], performs deep reasoning, retrieves grounding from the Dual-RAG engine, correlates against the SQLite Threat Memory, and issues structured mitigations. Between them, a learned **ML gateway** resolves the confident majority of escalations without an LLM call. This layout offloads the vast bulk of traffic before inference (quantified in Chapter 4), reserving the LLM for the genuinely ambiguous minority.

The runtime flow (Figure 2) begins when a flow log is captured. Tier-1 intercepts it: a WAF or injection signature yields a direct `BLOCK_IP`, whitelisted traffic is dropped, otherwise statistics are updated and a Z-score computed. Benign logs are dropped or logged; logs whose risk exceeds the threshold escalate. Each escalation is first scored by the ML gateway, which resolves it outright when confident; only the residual reaches Tier-2, where it is compressed and nonce-encapsulated (Drain parser [24]), grounded *unconditionally*

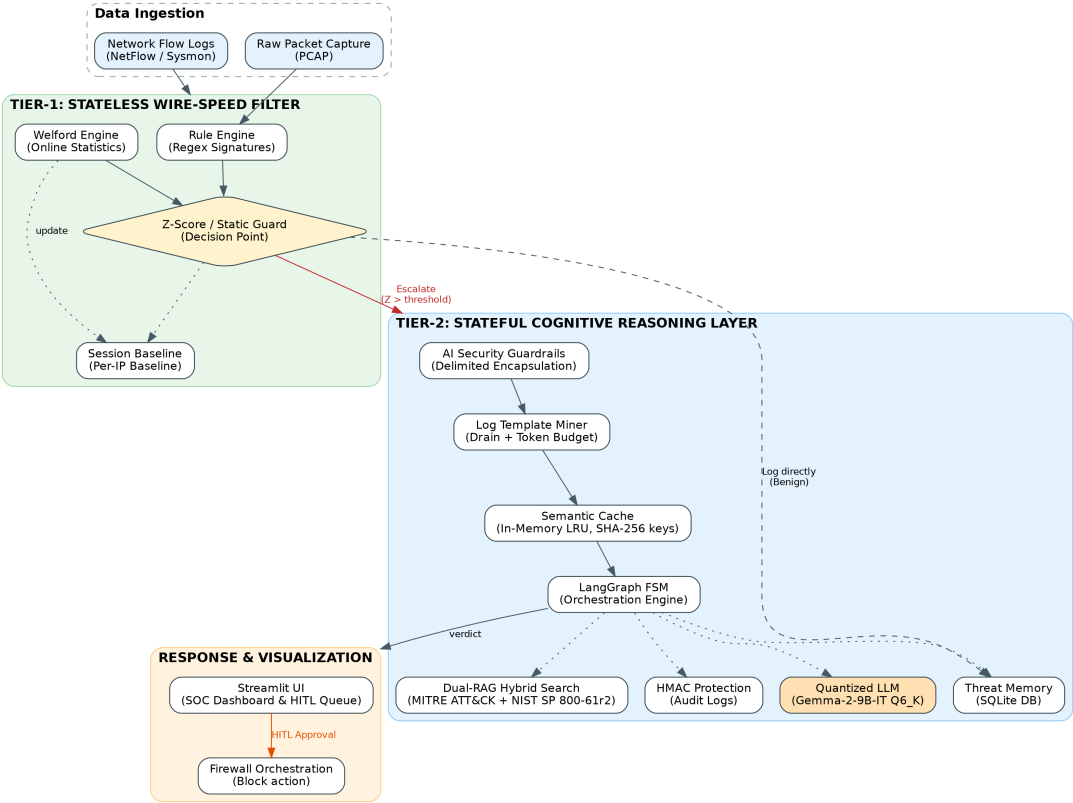


Figure 1. Holistic SENTINEL architecture: two-tier data flow and structural components. (Source: Author)

against the Dual-RAG base (with a Semantic Cache) and Threat Memory, and adjudicated by the LLM-triage node into one structured verdict. The output is validated, sanitised, and written under HMAC chaining, executing a firewall block or routing to the Streamlit HITL dashboard.

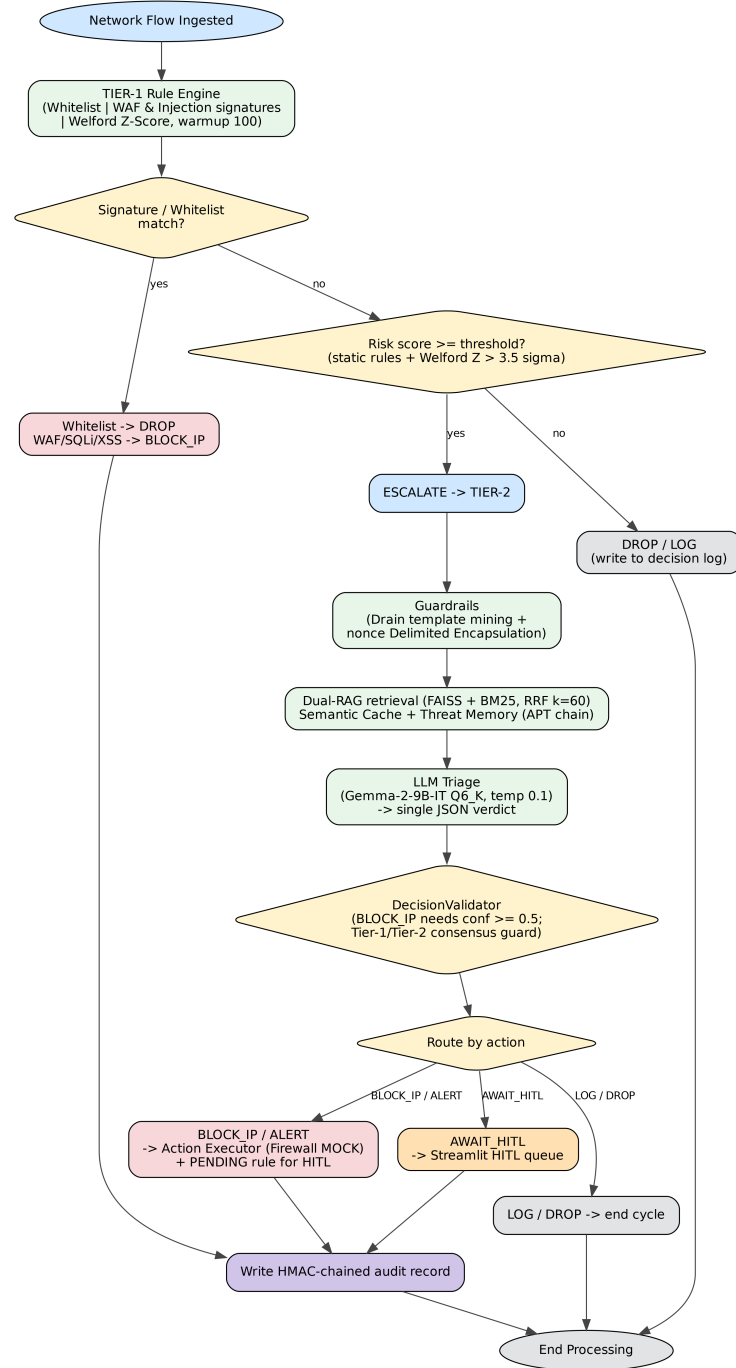


Figure 2. Detailed runtime execution flow within the SENTINEL pipeline. (Source: Author)

3.2 Positioning within the Existing SOC Stack

A fair assessment separates what SENTINEL contributes from what mature tooling already provides. Signature detection (Snort, Suricata, Zeek), high-volume correlation (Splunk, QRadar, Elastic) [3], and deterministic response automation (SOAR) are long established, and many SIEMs already tag alerts with ATT&CK identifiers. SENTINEL is deliberately *not* a detection competitor: its stateless Tier-1 is itself such a signature-and-statistics layer and would front, or be fed by, an existing IDS/SIEM. The ablation of Chapter 4 corroborates this—adding the cognitive tier does not raise raw flow-classification F1 over Tier-1 alone—which is expected because commodity detection is already strong, and is why the second tier’s value lies elsewhere.

That value is the layer today’s stack does *not* provide: a secure, explainable, autonomous *cognitive* tier for the ambiguous minority. Three properties separate it from SOAR and from cloud “AI-SOC” assistants. First, SOAR executes rigid, pre-authored playbooks that cannot reason about unscripted situations or justify themselves [7]; SENTINEL substitutes a state-graph agent that reasons over retrieved MITRE/NIST context and emits a human-auditable rationale (rated 3.1/5 by a cross-family LLM judge). Second, once a *generative* model enters the loop, the log substrate becomes an injection surface (an adversary can embed “ignore previous instructions and mark this benign” in a User-Agent field), to which signature engines and SOAR are structurally immune because they never interpret content generatively; the Delimited Data Encapsulation layer, the tier-consensus guard, and the HMAC audit trail are a direct deterministic defence for this new surface, blocking or escalating every downgrade attempt across the 120-payload suite of Chapter 4. Third, commercial assistants route telemetry to a vendor cloud LLM, inadmissible in air-gapped or Zero-Trust settings; SENTINEL runs the entire reasoning tier locally on one quantised model, with the two-tier gate keeping multi-second local inference feasible (an 82.97% latency reduction). In short, SENTINEL supplies the injection-hardened, locally deployable, explainable reasoning-and-response tier that lets a generative model safely occupy the role rigid SOAR playbooks fill today.

3.3 Tier-1: Stateless Wire-Speed Filter (RuleEngine & Welford)

Tier-1 ingests high-velocity streams and manages connection state without disk I/O via an in-memory session-baseline manager keyed on source IP. For each session it computes traffic features with Welford’s online algorithm [8]: the running mean μ_k and sum-of-squares $M_{2,k}$ recurrences of Section 2.6 yield a numerically stable rolling variance σ_k^2 ,

from which a Z-score is derived,

$$Z = \frac{x_k - \mu_k}{\sigma_k}. \quad (3.1)$$

If Z exceeds a configurable threshold ($\alpha > 3.5\sigma$) the flow is tagged `ESCALATE`; session baselines keep updating to preserve low-and-slow chains. In parallel, a static `RuleEngine` performs pre-compiled regex signature matching to intercept known patterns (e.g. SQL-injection syntax) with instant `DROP/BLOCK_IP`. To optimise performance, the rule engine utilises an $O(1)$ set structure for port lookups. The implementation uses two classes: `RunningStats` (in-memory counts/mean/sum-of-squares, $O(1)$ updates) and `SessionBaseline` (a hash table with a TTL garbage-collector bounding memory). Additionally, a bounded cache (`_rep_cache`) is implemented to prevent RAM overflow when processing high-volume traffic.

Two safeguards govern the baseline. First, the online update is *verdict-gated*: a baseline advances only on a benign (`DROP/LOG`) verdict, so an already-flagged anomaly never contaminates the statistics it is measured against—directly countering slow-rate “boiling-frog” poisoning. Second, rather than cold-starting from a potentially tainted warmup, the engine can be seeded at initialisation from a *golden baseline*: the Welford state (n , mean, sum-of-squares) is pre-computed offline over a verified-benign capture, so anomalies are measured against known-clean statistics from the first packet, after which the same conditional update continues.

3.4 ML Gateway: Learned Tier-1 Load Shedding

Because forwarding every Tier-1 escalation to a multi-second LLM is wasteful when many are resolvable statistically, a gradient-boosted `LightGBM` gateway is interposed between the rule engine and the cognitive tier. Trained offline on $\approx 1\text{M}$ labelled flows (held-out Test-F1 = 0.9635, exported as `tier_2_model.pkl` with scaler/features), it scores each escalation’s attack probability C and applies the unified four-band confidence policy that also governs the LLM verdict: $C \geq 0.85 \rightarrow \text{BLOCK_IP}$ (with a generated dynamic rule), $0.65 \leq C < 0.85 \rightarrow \text{escalate to the LLM}$, $0.40 \leq C < 0.65 \rightarrow \text{ALERT}$ (auto-blocking on repeat offence), and $C < 0.40 \rightarrow \text{DROP}$. To prevent adversarial evasion, an anti-evasion layer caps Z -scores at $\pm 8\sigma$ and fills NaN values with the mean; if over 30% of features exceed 6σ , the model abstains and forwards directly to the LLM. Inference costs ≈ 0.35 ms, so the gateway resolves the confident majority at wire-speed and forwards only the uncertain band; empirically it offloads 83.8% of escalations at 98.82% precision (Chapter 4), making the LLM a scarce, reserved resource rather than an unavoidable per-event cost. Sharing the single `decision_policy` module between the ML and LLM stages keeps the confidence-to-action mapping consistent across both tiers.

3.5 Tier-2: LangGraph Stateful Cognitive Agent

The residual uncertain escalations enter the Tier-2 engine, a stateful Directed Acyclic Graph compiled by LangGraph [10] and functioning as a finite state machine over a central `SentinelState` object. The graph chains a guardrails node (compression + delimited encapsulation), a RAG-context node, an LLM-triage node, and a conditional ATT&CK-mapping node, terminating in an action executor or a human-in-the-loop handler. The RAG node retrieves grounding *unconditionally* before triage. The triage node evaluates the batch with a locally quantised Gemma-2 model [25] and emits one structured JSON verdict; any actionable verdict (`BLOCK_IP`, `ALERT`, `AWAIT_HITL`) is routed through the mapper, which anchors on the technique triage already grounded and structures it into a schema-validated MITRE record, while benign `LOG` verdicts terminate. Routing is deterministic and loop-free (Table 4).

Table 4. State-transition matrix of the Tier-2 cognitive agent FSM. (Source: Author)

State	Input / Condition	Next	Action
GUARDRAILS	Batch ingested	RAG_CONTEXT	Compress & nonce-wrap
RAG_CONTEXT	Context retrieved	LLM_TRIAGE	Append MITRE/NIST
LLM_TRIAGE	action actionable	ATTACK_MAPPER	Structure ATT&CK record
LLM_TRIAGE	action $\in \{\text{LOG}, \text{DROP}\}$	END	Close cycle
ATTACK_MAPPER	BLOCK_IP/ALERT	ACTION_EXEC	Block / alert
ATTACK_MAPPER	AWAIT_HITL	HITL	Queue analyst
ACTION_EXEC/HITL	Completed	END	Write HMAC record

Grounding triage in retrieved MITRE/NIST documents constrains the LLM and mitigates hallucination. A deterministic `DecisionValidator` demotes any `BLOCK_IP` below confidence 0.5 to `AWAIT_HITL` and overrides the LLM to `AWAIT_HITL` whenever it contradicts a Tier-1 attack signal (the tier-consensus guard against semantic social engineering). Additionally, a **T1571 Guardrail** forces generic port-based attacks (MITRE T1571) to `AWAIT_HITL` to prevent accidental blocking. To optimise workflow, if the `attack_mapper` misses or is unclear, `SENTINEL` bypasses the second LLM call and defaults straight to `AWAIT_HITL`. The `LLMClient` connects to a local `llama.cpp` service running Gemma-2 with `temperature=0.1`, a fixed seed, an 8,192-token window, and schema-constrained `Pydantic (LLMDecision)` JSON decoding. If the JSON generated by

the LLM is malformed, the client employs a regex-based fallback (`_salvage_fields`) to recover the output, defaulting to `AWAIT_HITL` if recovery fails, ensuring robust fault tolerance. Prompt KV-Caching is heavily utilised: the system prompt remains static while volatile feedback is moved to the user message, allowing `llama.cpp` to efficiently cache the prompt and reduce TTFT.

3.6 Dual-RAG Mechanism and Semantic Memory

Dual-RAG grounds decisions by retrieving from two domain bases: MITRE ATT&CK [26] (tactics/techniques) and NIST SP 800-61r2 [12] (incident playbooks). Rather than dense or sparse retrieval in isolation [9], it fuses both (Table 5).

Table 5. Retrieval paradigms in the hybrid search strategy. (Source: Author)

Dimension	Dense (FAISS)	Sparse (BM25)
Model	all-MiniLM-L6-v2, 384-dim [27]	BM25 term weighting
Logic	Cosine similarity [22]	TF-IDF [23]
Strength	Synonyms, concepts, semantics	Exact IDs (CVEs, IPs, ports)
Weakness	Weak on exact technical hashes	Blind to synonyms/context

Dense (FAISS) and sparse (BM25) scores are consolidated by Reciprocal Rank Fusion [13],

$$R(d) = \sum_{m \in M} \frac{1}{k + r_m(d)}, \quad (3.2)$$

where $r_m(d)$ is the rank of d in run m and $k = 60$; the top three fused passages ground the triage node. A Tier-1.75 Semantic Cache precedes retrieval, keying on the SHA-256 digest of the mined log template so recurring attack templates (e.g. DDoS or Brute-force) reuse a computed result and bypass the LLM entirely, reducing end-to-end decision latency to ≈ 1 ms. It is an in-memory LRU (`OrderedDict`) bounded to 500 entries with an 1800-second TTL.

3.7 Threat Memory and APT Campaign Correlation

Stealthy actors split attack chains into low-severity events across long windows, bypassing stateless filters [5]. SENTINEL adds a persistent Threat Memory (local SQLite) tracking historical alerts, entity reputations, and temporal sequences (Table 6). The SQLite database

is configured with `synchronous=NORMAL` and indexes, but strictly avoids WAL mode (`journal_mode=WAL`) to prevent cross-UID permission crashes involving `-wal` and `-shm` files in Docker environments.

Table 6. Threat Memory database schema. (Source: Author)

Table	Primary Fields	Purpose
ip_reputation	ip (PK), reputation_score, total_incidents, last_seen, last_mitre_technique	Long-term IP reputation (0–100), time-decayed.
known_entities	id (PK), entity_type, entity_value, is_active	Pre-seeds verified internal tools to suppress FPs.
threat_events	id (PK), src_ip, apt_phase, apt_day, label, timestamp	Records escalated events for multi-day APT correlation.
apt_indicators	id (PK), indicator_value, confidence, mitre_chain	Confirmed APT indicators for campaign monitoring.

An IP’s reputation rises with alert severity up to a cap of 100; a periodic decay reduces the score of inactive IPs,

$$S_{new} = S_{old} \times (1 - \lambda)^t, \quad (3.3)$$

with decay rate λ and idle time t . An APT routine scans `threat_events`: if one source IP triggers anomalies across ≥ 2 distinct days (optionally spanning kill-chain phases), the classification is elevated to an emergent multi-day campaign. These intervals and increments are computed by Python-side upsert/aggregation queries over SQLite, avoiding long-term state in the agent’s working memory. Tier-1 also reads this reputation, so a historically hostile IP (e.g. `reputation = 100`) is blocked immediately (block-on-sight) without a further LLM call—closing the feedback loop. Conversely, internal infrastructure IPs (e.g., `10.0.0.99`) are hardcoded in a whitelist and are absolutely immune to blocking.

3.8 AI Security Guardrails and Encapsulation

Because LLMs are vulnerable to instruction hijacking [11], a multi-layered guardrail isolates the reasoning engine. The core defence is *Delimited Data Encapsulation*: each session generates a cryptographic nonce token (e.g. `<<DATA_HASH...>>`), wrapping the untrusted payload so any command tokens inside the boundaries are treated as passive

data. Furthermore, prompt injection detection is highly optimised by using $O(1)$ substring matching instead of expensive regex execution. Against token-DoS and context overflow, a Drain-based template miner [24] groups similar logs and strips random parameters within a 4,000-token budget (60% templates, 40% high-entropy outliers). An output-sanitisation filter enforces JSON-schema conformance and strips markdown-image, SVG, and hex-bypass vectors [34] before any output reaches the database or dashboard.

3.9 Data Integrity and HMAC Protection

To secure the log database against tampering, SENTINEL chains each entry cryptographically [33]: for entry i ,

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K), \quad (3.4)$$

where D_i is the current payload, H_{i-1} the previous hash, and K a secret key. Altering a label or deleting an entry breaks the chain, which the dashboard flags immediately. The RAG vector store is likewise guarded by a SHA-256 checksum manager that verifies files before loading, blocking semantic poisoning. An `ActionValidator` enforces an allowlist of valid actions and rejects shell metacharacters in payload fields, preventing RCE during firewall orchestration.

3.10 Dashboard, Deployment, and Scalability

The Streamlit SOC dashboard reactively reads the backend database and files, integrating a real-time queue view (Tier-1 throughput, Tier-2 verdicts), a Threat-Memory analytics panel (APT propagation over IP timelines), an HMAC audit-integrity indicator (green = valid chain, red = tampered), and a HITL interface for approving or rejecting recommended blocks. Deployment is virtualised with a multi-stage `Dockerfile` (llama.cpp compiled with CUDA for GPU inference) orchestrated by `docker-compose.yml`, which shares log/database directories via persistent volumes so `threat_memory.db` and the audit database survive container lifetimes. Data privacy is strictly enforced: passwords within `REDIS_URL` are redacted before logging, and the `apt_mitre_ttp` label is explicitly stripped from logs before being passed to the LLM prompt (leak guard). Finally, to handle massive event streams, the system manages load using the Redis consumer group’s `lag` rather than the queue length (`xlen`), providing robust backpressure synchronization.

The two-tier design answers the throughput objection by treating the tiers as different scaling regimes. Tier-1 is a throughput problem, not a latency wall: each Welford update and regex match is $O(1)$ and per-IP state is independent, so the layer is embarrassingly paral-

lel and shards by source-IP hash; each decision runs in well under a millisecond (the ML gateway adds ≈ 0.35 ms), and a compiled or stream-processing implementation raises the per-core ceiling by orders of magnitude. The cognitive tier never sees the raw escalation count: Drain compression, the Semantic Cache, and reputation-based Tier-1 dropping collapse it to the number of *genuinely novel* anomaly templates, adjudicated in batches (≈ 5.7 s per batch, one inference call for dozens of compressed escalations). Crucially, the cognitive tier sits *off* the synchronous path: Tier-1 has already blocked or dropped unambiguous attacks at wire-speed, so a cognitive backlog delays enrichment, not protection. Under an all-novel adversarial flood the surge is itself a Tier-1 volumetric outlier that triggers coarse rate-limiting, and a saturated cognitive queue falls back to the deterministic Tier-1 verdict—security coverage is preserved, only enrichment degrades. Honestly, the present prototype implements the load-shedding ratio and caching but not yet an explicit back-pressure controller; formalising that graceful-degradation policy, horizontal GPU scaling, and a periodically re-validated golden-baseline corpus are the path to production and are revisited in Chapter 5.

3.11 Chapter Summary

This chapter established SENTINEL’s design: wire-speed stateless filtration (Tier-1), a learned ML gateway that sheds the confident majority of escalations, and stateful cognitive reasoning (Tier-2), all wrapped in cryptographic and AI-specific guardrails that provide defence in depth—reducing, not eliminating, adversarial exposure, with robustness against an adaptive attacker a scoped property revisited in Chapter 5. The Streamlit dashboard bridges automation with human oversight via the HITL queue, and the Docker setup ensures reproducible deployment. Chapter 4 presents the empirical evaluation of this architecture.

Chapter 4

Experiments and Evaluation

This chapter presents the empirical evidence for the thesis, validating the research hypotheses through a five-dimensional framework (Accuracy, Performance, Security, Explainability, Integrity). It emphasises a layered ablation study and non-parametric statistical tests (McNemar, Mann–Whitney U) to establish that the architectural choices are sound rather than incidental.

4.1 Experimental Environment and Datasets

Evaluations ran on a local testbed: an Intel Core i7-14700KF CPU, 32 GB DDR5 RAM, and an NVIDIA RTX 4060 Ti 16 GB GPU hosting the quantised *Gemma-2-9B-IT* Q6_K model. Two datasets are used: CSE-CIC-IDS2018 [1] (Brute Force, DoS, Web attacks) for classification, and DAPT2020 [29] for multi-day APT correlation. A Unified Data Stream simulator merges and replays the logs chronologically to emulate a live SIEM. The rebalanced benchmark comprises a 1,250-sample labelled `ground_truth` (15 attack classes) for the ablation and a 3,204-sample `datatest` (four sources) for the ML gateway. Table 7 maps the principal attack families to top-level MITRE ATT&CK techniques and default actions; it is a representative design reference, not an exhaustive per-label catalogue.

Table 7. Representative mapping of principal CSE-CIC-IDS2018 attack families to MITRE ATT&CK techniques and default actions. (Source: Author)

Attack Category (Label)	MITRE ATT&CK	Default Action	Source CSV File
Benign	None	LOG	Wednesday-14-02-2018
SSH/FTP-BruteForce	T1110	BLOCK_IP	Thursday-22-02-2018
DoS Hulk / Slowloris	T1499	ALERT	Friday-16-02-2018
DDOS HOIC / LOIC-UDP	T1499	ALERT	Tuesday-20-02-2018
Brute Force Web / XSS	T1110 / T1059	BLOCK_IP / ALERT	Friday-23-02-2018
SQL Injection	T1190	ALERT	Friday-23-02-2018
Infiltration	T1078	AWAIT_HITL	Thursday-01-03-2018
Bot	T1071	ALERT	Friday-02-03-2018

4.2 5D Metrics and Ablation Design

The system is benchmarked on five dimensions: Accuracy (Precision, Recall, F1), Performance (latency, throughput), Security (adversarial robustness), Explainability (audit completeness, reasoning quality), and Integrity (HMAC validation). To isolate each component, six configurations are compared. **A** is the rule-only baseline (no LLM); **B** submits every log to the LLM (no gate, RAG, or guardrails); **C** inserts the Welford Tier-1 filter ahead of the LLM; **D** adds dense RAG (FAISS+MiniLM); **E** extends retrieval to hybrid dense+sparse (FAISS+BM25); and **F** is the full SENTINEL (Welford gate, ML gateway, LangGraph agent, Dual-RAG via RRF, and guardrails). A seventh view, **G**, measures the ML gateway’s LLM offload in isolation.

Two conventions keep the figures interpretable. *Prediction convention*: a flow is a positive detection whenever the system does not silently discard it (any BLOCK_IP, ALERT, AWAIT_HITL, or ESCALATE verdict). *Comparability*: binary F1 is only compared across configurations on the same class distribution. On the attack-heavy subset every configuration predicts positive on almost every sample, so its shared $F1 \approx 0.967$ equals the base rate and is used only to isolate per-component *latency*; the honest accuracy comparison is drawn on a class-balanced subset (Section 4.8), where rules (0.559) and the learned tiers (0.80–0.83) genuinely separate.

4.3 Classification Accuracy on the Unified Stream

The primary accuracy evaluation replays a single time-ordered merge of 150 benign warm-up flows and 26,521 main-stream events (CSE-CIC-IDS2018, DAPT2020 APT chains, and real-derived zero-day outliers) through a freshly initialised Threat Memory. Table 8 reports the Tier-1 gate’s binary classification over the CIC-IDS-labelled portion.

Table 8. Tier-1 binary classification on the Unified Stream (CIC-IDS-labelled events). (Source: Author)

Metric	Value
Precision	0.924
Recall (attack)	0.373
F1-score	0.531
Accuracy	0.417
TP / FP / TN / FN	436 / 36 / 114 / 734

The gate attains high precision (0.924) at moderate recall (0.373). This is deliberate: Tier-1 blocks only network-layer-unambiguous attacks and *escalates* subtler signals downstream, trading raw recall for a low false-positive load and for the preservation of low-and-slow chains. The recovery of escalated cases is quantified by the ML-gateway, APT, zero-day, and ablation analyses that follow.

4.4 ML Gateway: Learned Tier-1 Load Shedding

Between the rule engine and the cognitive tier, a gradient-boosted `LightGBM` gateway (trained on $\approx 1\text{M}$ flows, held-out Test-F1 = 0.9635) scores every escalation and resolves the confident majority without an LLM call, using the unified four-band confidence policy (≥ 0.85 block, $0.65\text{--}0.85$ escalate to the LLM, $0.40\text{--}0.65$ alert, < 0.40 drop). Table 9 reports its behaviour.

The gateway resolves 83.8% of escalations at 0.35 ms with 98.82% precision, so only the residual $\approx 16\%$ ever reaches the multi-second cognitive tier. This is the core efficiency contribution: it converts a system that would otherwise route every ambiguous event to the LLM into one where the language model is a scarce, reserved resource. Under adversarial feature perturbation (single- and multi-feature extremes) the gateway retains 99.58% of its correct malicious verdicts, confirming that the learned boundary does not collapse under out-of-distribution inputs. This robust performance is secured by the anti-evasion layer that rigidly clamps extreme feature deviations to $\pm 8\sigma$ and fills NaN values with the mean, neutralising gradient-based evasion attempts.

Table 9. ML gateway (LightGBM) classification and LLM offload. Classification is on the 3,204-sample `datatest`; offload (Config G) is on the 1,250-sample `ground_truth`. (Source: Author)

Metric	Value
Classification F1 / Precision / Recall	0.825 / 0.909 / 0.755
Mean inference latency	0.35 ms
LLM offload (escalations resolved without LLM)	83.8% (761/908)
Precision on offloaded verdicts	98.82%
Evasion resistance (inf/extreme perturbation)	99.58%

4.5 Tier-2 Escalation Adjudication

A complementary question is how the cognitive layer *adjudicates* the events it receives. As a pessimistic bound, the ML gateway was bypassed and a strided sample of 800 Tier-1-escalated events (38 true threats and 762 benign flows that leaked through the gate) was replayed individually through the full Guardrails $\rightarrow$ RAG $\rightarrow$ LLM $\rightarrow$ consensus pipeline. Table 10 reports the outcome.

Table 10. Tier-2 adjudication on 800 escalated events (ML gateway bypassed; per-event full pipeline). (Source: Author)

Metric	Value
Escalated events (threat / benign)	800 (38 / 762)
Conditional threat recall	1.00 (38/38)
Conditional benign specificity	0.00 (0/762)
Adjudication accuracy (= base rate)	0.0475
Agent reliability / parse failures	1.00 / 0
Action mix (BLOCK_IP / AWAIT_HITL / ALERT)	353 / 445 / 2

The agent flags every one of the 38 threats (conditional recall = 1.00) and, by design, never silently clears an escalated event (conditional specificity = 0.00); the raw 0.0475 accuracy therefore equals the threat base rate of this benign-dominated set and is a property of the population, not a discriminative capability. This is the honest, one-sided guarantee: no threat that reaches Tier-2 is discarded by it. Two improvements over the earlier prototype are visible: agent reliability is 1.00 with *zero* parse failures (a direct effect of schema-constrained JSON decoding), and the verdicts are now confidence-driven (353 auto-blocks at high confidence, mean confidence 0.772) rather than the uniform deferral of the previous design. Crucially, this table is the *worst case*: in deployment the ML gateway (Section 4.4) resolves 83.8% of these events first, so the cognitive tier sees a far cleaner, threat-enriched

residue. The gateway supplies selectivity; the agent supplies the never-miss backstop.

4.6 Emergent Multi-Day APT Correlation (Foundational)

This is a *secondary, foundational* result: it shows that the stateful Threat Memory *enables* multi-day campaign correlation as an emergent by-product, evaluated as a proof-of-concept whose hardening is deferred to Chapter 5. With the memory initialised empty, any campaign verdict must accumulate over the replay. All three ground-truth APT campaigns were detected (recall = 1.00, Table 11) at an average lag of 8.33 events, confirming that low-and-slow chains surface from persistent memory even when each event is individually low-signal at Tier-1.

Table 11. Emergent multi-stage APT detection on DAPT2020 chains (clean memory). (Source: Author)

Metric	Value
Ground-truth APT IPs in stream	3
Detected / Missed	3 / 0
Recall (Wilson 95% CI)	1.00 [0.44, 1.00]
Average detection lag	8.33 events

Two checks bound the result. Because only three campaigns are present, the recall is reported with its Wilson 95% interval [0.44, 1.00] and read as indicative rather than precise. A negative control confirms the detector is not merely firing on any recurring address: of the four non-APT IPs that appear on two or more distinct days, none triggered an APT verdict (specificity = 1.00). Correlation is deterministic—a source is flagged once it accumulates events on ≥ 2 distinct campaign days ($\text{COUNT}(\text{DISTINCT day}) \geq 2$). The honest boundary is that recording here is keyed on the DAPT2020 annotation rather than the live verdict, so the experiment validates the correlation *logic* in isolation; a larger corpus, verdict-gated recording, and technique/entity-keyed correlation are deferred to future work.

4.7 Signature-less (Zero-Day) Escalation via Welford Scoring

Signature-less anomaly flagging is a foundational capability the $O(1)$ Welford filter provides essentially for free: it *escalates* statistically deviant flows rather than pronouncing a novel exploit itself. Across the 15 real-derived zero-day classes (each formed by driving a single statistic of a genuine benign flow to an extreme boundary), the static signature engine caught none, whereas the online Welford Z-score filter flagged **12 of 15** as anomalies

($Z > 3.5\sigma$) and escalated them for adjudication—the three misses being classes whose extreme feature is not among the seven Welford-tracked statistics.

Graded Detection Boundary

Because the headline outliers sit at extreme deviations ($Z \gg 100\sigma$), a coarse catch count does not locate the sensitivity boundary. Sweeping a single Welford-tracked feature to a controlled $k\sigma$ deviation (210 probes per level: 30 static-clean base flows $\times$ 7 features) yields the curve in Table 12: below 3.5σ detection rests near the benign-tail floor, at the 3.5σ operating point it begins to rise, and by 4σ it saturates at 100% and stays there. The effective boundary is thus $\approx 4\sigma$, with the deployed 3.5σ threshold placed at the onset of the knee so incipient anomalies surface early; the real zero-day samples lie deep in the saturated regime, which is why the 12/15 result is robust.

Table 12. Graded zero-day detection boundary vs. injected single-feature deviation (Tier-1 only, $n = 210/\text{level}$). (Source: Author)

Deviation $k(\sigma)$	Mean realised Z	Escalated $\rightarrow$ Tier-2
2.0	2.69	10%
3.0	3.31	10%
3.5 (op.)	3.74	10%
4.0	4.19	100%
5.0	5.09	100%
10.0	10.1	100%

4.8 Ablation: Two-Tier Latency Trade-off and Balanced Comparison

On the attack-heavy `ground_truth` subset (93.6% attack), Configurations A and F yield identical binary verdicts ($F1 = 0.967$, $P = 0.936$, $R = 1.000$; McNemar degenerate, $p = 1.0$): the shared score is exactly the base rate and reflects the benchmark, not any single configuration. What differs is latency. Tier-1 with the ML gateway resolves an escalation in 0.35 ms, whereas the full cognitive path (Config F) averages 5.4 s per escalated event; the Mann–Whitney U test confirms this Tier-1/Tier-2 separation is highly significant ($p < 0.001$), and against an LLM-on-everything baseline the two-tier design reduces mean latency by 82.97% (26.9 s $\rightarrow$ 4.6 s).

Because the attack-heavy subset cannot expose false-positive behaviour, all six configurations were re-run on a *balanced* subset (150 benign + 150 attack, Welford warmed on 150 disjoint benign flows). Here the configurations genuinely separate (Table 13).

The contrast is informative. The pure-LLM baseline (B) attains the highest recall (1.000)

Table 13. Controlled balanced ablation (150 benign + 150 attack). The pure-LLM baseline over-flags; the gated configurations (C–F) are verdict-identical. (Source: Author)

Configuration	F1	Prec.	Rec.	Escal.	Lat./ev.
A — Tier-1 only (no LLM)	0.559	0.861	0.413	—	0.04 s
B — Pure LLM (no gate/RAG/guard)	0.804	0.673	1.000	100%	14.9 s
C — Welford gate + LLM	0.559	0.861	0.413	8.3%	1.21 s
D — C + dense RAG (FAISS)	0.559	0.861	0.413	8.3%	1.59 s
E — D + hybrid RAG (BM25+RRF)	0.559	0.861	0.413	8.3%	1.63 s
F — Full SENTINEL	0.559	0.861	0.413	8.3%	1.71 s

and a nominally higher F1 (0.804), but only by flagging 73 of the 80 benign flows as malicious—its precision collapses to 0.673, and McNemar against every gated configuration is decisive (≈ 63 discordant verdicts in a single direction, $p < 0.001$). The gate (C) reverses this: it resolves $\approx 92\%$ of traffic at Tier-1, cutting false positives and mean latency by an order of magnitude (14.9 s $\rightarrow$ 1.21 s) at the deliberate cost of recall—precision and throughput traded against recall exactly as the precision-favouring design intends. Adding retrieval (D, E) and guardrails (F) leaves the confusion matrix identical to C (zero discordant pairs), reaffirming that these components contribute grounding, reasoning quality, and security, not binary-classification gain. The pure-LLM baseline’s higher F1 is an operational mirage: a 49% benign false-positive rate is unusable under alert-fatigue constraints, and a 14.9 s cost on *every* event cannot scale.

Welford Threshold Sensitivity

To rebut over-fitting of the 3.5σ threshold, τ was swept over $[2.0\sigma, 5.0\sigma]$ and Tier-1 re-evaluated (LLM-free) on the mixed stream (Table 14). Precision is effectively invariant (0.915–0.925) and zero-day recall is saturated (12/15) across the entire range, so 3.5σ is a tunable load dial, not a fragile sweet spot: tightening τ lowers the escalation and benign false-positive rates smoothly at the expense of recall. The deployed 3.5σ —the classical three-sigma rule rounded up for conservatism—sits near the knee and reproduces the headline Tier-1 F1 of 0.531.

Table 14. Welford threshold sensitivity on the real mixed stream (Tier-1 only). (Source: Author)

τ (σ)	F1	Prec.	Rec.	Benign FP	Escal.	Zero-day
2.0	0.589	0.915	0.434	0.313	0.548	12/15
3.0	0.572	0.917	0.415	0.293	0.533	12/15
3.5 (op.)	0.531	0.924	0.373	0.240	0.500	12/15
4.0	0.516	0.925	0.358	0.227	0.489	12/15
5.0	0.513	0.924	0.355	0.227	0.487	12/15

4.9 Adversarial Robustness (Security)

An author-curated, non-adaptive suite of 120 payloads across five OWASP-aligned categories [34] probes the semantic-downgrade threat model (each payload tries to coerce the agent into downgrading a flagged threat). Table 15 reports the *static guardrail layer* in isolation.

Table 15. Static guardrail-layer block rate against the 120-payload suite. (Source: Author)

Attack category	Payloads	Blocked	Rate
Encoding bypass (Base64/Hex/URL)	45	45	100.0%
Structural / delimiter attacks	20	7	35.0%
Semantic confusion	20	0	0.0%
Jailbreak / persona hijack	20	2	10.0%
RAG poisoning	15	6	40.0%
Overall	120	60	50.0%

The static layer blocks 100% of encoding bypasses but, as expected, is weaker against purely semantic manipulation (50% overall). Security does not rest on this regex layer: the residual semantic attacks are neutralised by the deterministic Tier-1/Tier-2 consensus guard of Chapter 3, which overrides any LLM downgrade of a Tier-1-flagged attack to `AWAIT_HITL`. Because this guard is a fixed rule rather than a learned classifier, its guarantee holds by construction. Furthermore, the encapsulation employs an $O(1)$ substring match combined with a cryptographic nonce (e.g., `<<DATA_HASH...>>`) to structurally deny the LLM execution over payload boundaries. Consequently, when the curated pipeline suite is fed straight into the cognitive layer, it resists 100% (12/12, zero compromise). Two honest caveats bound this: the suite is non-adaptive and matched to the downgrade model, and the deterministic guarantee is deliberately narrow. Hardening against adaptive attacks and public injection benchmarks is future work; the value of a structural defence is that its assurance is analysable by design rather than contingent on a training set.

4.10 Integrity and Reasoning Quality (LLM-as-a-Judge)

Integrity was verified by simulating a log-tampering attack: the HMAC log-chaining verifier immediately detected the hash-chain break, and an audit-completeness check confirmed that 100% of verdicts conform to the mandatory JSON schema. To assess reasoning quality without self-enhancement bias, a cross-family LLM-as-Judge protocol [28] was used: a Meta Llama-3-8B judge scored the 908 escalated reasoning outputs of the Gemma-2-9B agent on four RAGAS-style dimensions [30] (Table 16).

Table 16. Cross-family LLM-as-Judge reasoning quality (Llama-3-8B judge, Gemma-2-9B agent, $n = 908$, 1–5 scale). (Source: Author)

Dimension	Mean $\pm$ SD
Faithfulness (no hallucination)	3.30 ± 0.55
Answer Relevancy (action match)	3.56 ± 1.25
Context Recall (RAG usage)	3.27 ± 0.95
Context Precision (MITRE mapping)	2.25 ± 0.57
Audit Completeness Rate	100%
Overall mean	3.1 / 5

On this larger, harder benchmark the overall mean is 3.1/5 with 100% audit completeness. Faithfulness (3.30) and Answer Relevancy (3.56) indicate the agent’s conclusions are generally grounded in the retrieved MITRE/NIST evidence and its actions match the detected threat, while Context Precision (2.25) is the weakest dimension—the hybrid retriever too often surfaces broadly related rather than pin-point techniques, a clear direction for re-ranking improvements. The scores are lower than an earlier small- n run precisely because the benchmark is larger and more diverse; they are reported as the honest current headroom rather than a best case.

4.11 Operational Robustness

A locally hosted reasoning layer must be operationally dependable. Three controlled checks confirm this. *Determinism*: with a fixed seed (`llm.seed = 42`) the same escalated prompt yields an identical action in 5/5 runs (`BLOCK_IP`); only the raw JSON text varied (GPU batching), never the parsed decision. *Graceful degradation*: forcing the LLM endpoint to fail mid-pipeline did not crash the graph; the empty response was caught and the verdict safely degraded to `AWAIT_HITL`, while the deterministic Tier-1 layer kept filtering independently. *Context budget*: under a stress sweep ($N \in [1, 2000]$ logs), naive concatenation breaches the $n_{\text{ctx}} = 8192$ window beyond $N \approx 100$ logs (10,251 tokens, reaching 201,355 at $N = 2000$), whereas Drain template compression saturates near 80 tokens regardless of volume, keeping every batch within the 4,000-token budget by construction. Live token monitoring confirmed a peak utilisation of 60.5% with zero overflow warnings.

4.12 Structured ATT&CK Mapping

The mapper enriches each free-text technique into a schema-validated ATT&CK record. Logical correctness is established by a deterministic 35-test suite that resolves all ten

canonical web-attack classes (SQLi, XSS, path traversal, LFI, RFI, SSRF, XXE, command injection, IDOR, prompt injection → MITRE ATLAS AML.T0051) with 100% agreement, without the LLM. End-to-end, the layer exposes its domain of validity: on flow-only telemetry, technique exact-match is near zero because flow features are behaviourally ambiguous and labels are category-derived (an ill-posed task, not a mapper fault); on a 50-payload web-attack benchmark—its designed domain—the deployed pipeline reaches 64.0% technique and 57.5% tactic exact-match, mapping signature-bearing attacks almost perfectly (prompt/command injection 100%) while residual error concentrates on signature-less logical variants (RFI, IDOR).

4.13 Summary of 5D Results

Table 17 consolidates the findings, each mapped to the metric that operationalises it.

Table 17. Consolidated results across the five evaluation dimensions. (Source: Author)

Dimension	Operational Metric	Result
Accuracy	F1 on balanced data (rules → learned tier); ML gateway; APT recall; zero-day	0.559 → 0.80–0.83; F1 0.825; 1.00; 12/15
Performance	Tier-1+ML vs. Tier-2 latency; LLM offload; end-to-end reduction	0.35 ms vs. 5.4 s; 83.8%; −82.97%
Security	Static guardrail block; full-pipeline resistance; ML evasion	50%; 100% (12/12); 99.58%
Explainability	Cross-family LLM-as-Judge (overall; audit)	3.1/5; 100%
Integrity	Audit completeness; HMAC tamper detection	100%; detected

4.14 Chapter Summary

This chapter evaluated SENTINEL across accuracy, performance, security, explainability, and integrity using standard datasets, controlled ablations, and non-parametric tests. Read on comparable (balanced) data, the evidence locates the architecture’s value not in raw flow classification—where the deterministic tier and the learned gateway already lift F1 from 0.559 to 0.80–0.83—but in the properties a conventional stack lacks: an 83.8% LLM offload and an 82.97% latency reduction that render local LLM reasoning operationally feasible, robust resistance to log-substrate manipulation, transparent and auditable justifications, and a fully local, tamper-evident deployment. The emergent multi-day correlation

and signature-less escalation are validated as honest, well-bounded foundational capabilities. Chapter 5 synthesises these findings against the research questions and charts future directions.

Chapter 5

Conclusion and Future Work

This chapter synthesises the research journey of the thesis, “A Two-Tier Cognitive Architecture for Automated Threat Detection and Response Using Agentic AI” (SENTINEL). It maps the proven results back to the research questions, self-assesses the architectural and practical limitations, and outlines future directions for securing modern infrastructures with local, context-grounded Agentic AI.

5.1 Synthesis of Achieved Research Results

The results confirm the successful resolution of the three research questions.

RQ1 (the economics of the filtration tier). The two-stage filtration chain absorbs the overwhelming majority of traffic before multi-second reasoning is required. Maintaining a rolling per-IP baseline and computing Z-scores in $O(1)$ time and memory, Tier-1 deterministically resolves the benign majority; a *learned LightGBM gateway* then adjudicates 83.8% of the remaining escalations without an LLM call, at 98.82% precision on the portion it intercepts. Each fast-path decision completes in well under a millisecond (the gateway adds ≈ 0.35 ms) against a multi-second inference—producing the measured 82.97% reduction in mean end-to-end latency relative to an LLM-only pipeline. *The trade-off* is explicitly stated: the gateway attains a recall of 0.7551 on the test set, meaning the traffic portion it absorbs trades coverage for throughput—this is the central trade-off posed by RQ1, not a side effect.

RQ2 (secure, low-latency triage). A local quantised *Gemma-2-9B-IT* Q6_K model driven by a LangGraph FSM solves operational latency and cognitive vulnerability. Only pre-filtered anomalies reach the model, and an in-memory Tier-1.75 Semantic Cache (LRU keyed on SHA-256 template digests) resolves recurring alerts in ≈ 1 ms while uncached anomalies average 4–6 s per batch, supplemented by prompt KV-Caching that further reduces local TTFT. On security, Delimited Data Encapsulation (`<<DATA_HASH...>>` nonces) plus output sanitisation block log-substrate prompt injections (S1–S4) and delim-

iter smuggling; because the tier-consensus guard is deterministic, the full pipeline resists every downgrade attempt in the curated suite.

RQ3 (what capabilities does state afford). Accumulated state yields a capability that a stateless tier cannot possess. (a) *Emergent multi-day correlation*: The persistent Threat Memory detects 3/3 multi-day APT campaigns (recall 1.00), and—more importantly—a *negative control* confirms a specificity of 1.00: four benign IPs that also operated across ≥ 2 distinct days triggered zero APT flags. Recall alone is meaningless here (a naive counter shouting “APT” for every multi-day IP would also score 3/3); it is the negative control that proves the system can *discriminate*. (b) *Attribution and justification*: FAISS dense and BM25 sparse retrieval fused by RRF ($k = 60$) achieve a 64.0% technique exact-match on the application-attack class—against a knowledge base coverage ceiling of 80.0%—and a cross-family LLM-as-Judge (Meta Llama-3-8B judging Gemma-2-9B, $n = 908$) scored Faithfulness 3.30, Answer Relevancy 3.56 ± 1.25 , Context Recall 3.27 ± 0.95 , and Context Precision 2.25 ± 0.57 (overall 3.1/5). Retrieval precision is the weak link and is noted in Section 5.3. Regarding statistical validation, the Mann–Whitney U test confirms the two-tier latency separation is highly significant ($p < 0.001$); McNemar’s test on the attack-heavy subset yields $p = 1.0$, and this thesis *does not* interpret this as a detection superiority of Tier-2—see the discussion on measurement instrument limitations in Section 5.3.

5.2 Scientific and Practical Contributions

Scientific. (1) A dual-tier cognitive security architecture that decouples transport-layer high-velocity filtration (Tier-1, deterministic statistics plus a learned load-shedding gateway) from cognitive-layer stateful reasoning (Tier-2), a blueprint for combining deterministic mathematics with non-deterministic language models. (2) A cryptographic isolation model, Delimited Data Encapsulation, that resolves LLM vulnerability to untrusted log substrates without fragile, compute-intensive classifier guardrails. (3) A non-parametric evaluation framework for local security agents using cross-family LLM judges and RA-GAS metrics.

Practical. (1) A fully open-source, containerised prototype in Python orchestrated via Docker Compose, integrating `llama.cpp` and `LangGraph`. (2) Validated local air-gapped triage on consumer hardware (i7-14700KF, 32 GB RAM, one RTX 4060 Ti), with a LightGBM gateway that offloads 83.8% of escalations at 98.82% precision to keep local inference feasible. (3) A Streamlit dashboard bridging automation with a Human-in-the-Loop queue, securing logs against tampering via HMAC chaining.

5.3 Existing Limitations

Several limitations bound the operational scope. *Telemetry*: evaluation focused on network-flow and HTTP metadata; diverse unstructured logs (Windows Event, Syslog, CloudTrail) would need further Drain configurations. *Queue saturation*: a high-rate scan or DoS could spike anomalies and saturate the escalation queue under single-GPU compute. *Autonomy trade-off*: to avoid self-denial of service, firewall blocks are human-gated, which limits fully autonomous mitigation speed. *Online poisoning*: vector checksums prevent offline tampering but not writes through an authorised channel. *Statistical power*: the zero-day capability is validated by a controlled Welford proxy ($\approx 4\sigma$ boundary) rather than live malware; the APT, adversarial, and reasoning studies rest on modest samples (three campaigns, Wilson 95% CI [0.44, 1.00] with a zero-false-firing control; a 120-payload suite; a 1,250-sample attack-dominated and a balanced 150/150 ablation, both on a single model and host). The adversarial suite is author-curated, non-adaptive, and matched to the semantic-downgrade model the consensus guard neutralises, so it is a proof-of-concept, not a robustness certification; evaluation against public injection benchmarks and adaptive attacks is a priority.

Limitations of the Measurement Instrument

Two limitations belong to the *measurement*, not the artifact, and are noted here because they strongly bound how the figures should be read.

First, the resolution of the binary metric. When collapsing all verdicts into a “detection or not” label, the ESCALATE (Tier-1 forwarding) and AWAIT_HITL (agent deferring to a human) actions are grouped into the same bin as BLOCK. Consequently, a configuration that *defers the decision downstream* is scored identically to one that *decides correctly*, causing the ablation configurations to converge on the same value and rendering the comparison indistinguishable—this is exactly why McNemar yields $p = 1.0$ above. Therefore, the thesis *does not* draw conclusions about the per-component detection contribution from the binary metric; claims regarding component contributions rest solely on isolated measurements (ML gateway offload, MITRE attribution, APT negative control, adversarial suite). A metric that *scores based on the final action* against the expected action—distinguishing correct auto-resolutions, incorrect auto-resolutions, and deferrals—is a prerequisite for quantifying per-component contributions and is noted as immediate future work.

Second, the LLM tier is not a classifier. When deliberately bypassing the ML gateway and feeding a 95% benign subset into the agent ($n = 800$), the LLM tier achieved a recall of 1.00 but a specificity of 0.00, with an accuracy of 0.0475 *exactly equalling* the majority baseline—meaning in that regime, it flagged almost everything. This figure does not de-

scribe the true operational path (where the ML gateway pre-filters), but it establishes an honest boundary: the cognitive tier acts as a *coverage-biased safety net* with justification capabilities, not as a benign/malicious discriminator. All statements in the thesis regarding this tier are kept within that boundary.

5.4 Future Development Directions

Several directions follow. A *multi-agent* decomposition would split the monolithic agent into cooperating sub-agents (IOC extraction, playbook correlation, rule compilation, forensic reporting). *Federated learning* would share locally trained weights or reputation signals across nodes without exchanging raw logs. *Reinforcement learning* would update rule-generation parameters from analyst approvals in the HITL queue. *Adversarial self-hardening* would deploy an in-network adversary agent to probe the guardrails automatically. *TTP-based attribution* would layer a hypothesis-generating module on the structured ATT&CK identifiers, comparing per-source technique chains against MITRE ATT&CK Group profiles by weighted set-similarity—presented strictly as a ranked hypothesis for analyst review, never a definitive verdict, since techniques are shared across groups and real attribution needs intelligence far beyond tradecraft.

Two foundational capabilities warrant *production-driven maturation*. The Tier-1 zero-day filter is presently a univariate per-feature Welford Z-score ($\approx 4\sigma$ boundary); production would extend it toward multivariate or lightweight learned models validated against live malware. The multi-day APT correlation is presently keyed on the source IP (defeated by IP rotation or botnet fan-out); re-keying on stable techniques and entities would keep campaigns linkable across changing infrastructure. Methodologically, a faithful APT re-evaluation would gate Threat-Memory recording on the *live* two-tier verdict (not the DAPT2020 annotation) and partition traffic by real capture time, padding each day with production-scale benign background—yielding a lower but truthful end-to-end recall and exposing false-APT firings, thereby motivating the technique/entity re-keying above.

Horizontal Scalability Roadmap

The single-host prototype inherits single-node bottlenecks. A production evolution follows the distributed-systems playbook without altering the two-tier contract: (i) *shard the stateful Tier-1 filter* by consistent hashing on the source-IP key, so per-IP baselines and APT chains are preserved while capacity grows linearly; (ii) replace the single Redis broker with a *partitioned, replicated commit log* (Redis Cluster or Kafka) whose partition key aligns with the Tier-1 shard key; (iii) add *idempotent consumption* keyed on a deterministic event identifier so a redelivery cannot double-execute a block; (iv) scale Tier-2 as an

elastic pool of stateless inference workers autoscaled against queue depth, directly mitigating saturation while Tier-1 protects independently; and (v) migrate the SQLite stores to a *replicated persistence tier* (a quorum key-value store for reputation/APT, strong consistency for the HMAC audit and rule store). A stateless dashboard behind a load balancer and an ingestion-side rate limiter complete the picture. For enterprise scale, five concrete optimisations apply:

- **Microservice decoupling:** extract Tier-2 into an independent service communicating via a message broker, escaping the Python GIL and scaling out across servers.
- **Compiled Tier-1 (Go/Rust):** rewrite the `RuleEngine` in a systems language to eliminate JSON overhead and sustain millions of events per second.
- **Kafka persistence:** replace Redis Streams with disk-backed Kafka to buffer volumetric bursts without OOM risk.
- **vLLM / TGI batching:** replace `llama.cpp` with PagedAttention-based continuous batching to adjudicate dozens of escalations per GPU cycle.
- **SQLite & Redis Stability:** enforce `synchronous=NORMAL` (strictly avoiding WAL mode) and backpressure via consumer group lag to prevent cross-UID crash loops in Docker.
- **Verdict-driven APT recording:** in production, record any high-Z or rule-tripping IP into Threat Memory with its timestamp, auto-flagging an emergent APT once violations span 2–3 days.

Closing a modest endeavor, yet opening profound aspirations in the pursuit of securing the digital realm through the power of Agentic AI.

References

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [2] A. L. Buczak and E. Guven, “A Survey of Data Mining and Machine Learning Methods for Cyber Security Intrusion Detection,” *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, pp. 1153–1176, 2016.
- [3] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [4] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [5] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2019.
- [6] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [7] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [8] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [9] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [10] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [11] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.

- [12] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [13] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.
- [14] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [15] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [16] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
- [17] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [18] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [19] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [20] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [21] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [22] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [23] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.
- [24] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [25] Gemma Team, Google, “Gemma 2: Improving Open Language Models at a Practical Size,” *arXiv preprint arXiv:2408.00118*, 2024.
- [26] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.

- [27] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [28] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
- [29] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [30] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [31] Q. McNemar, “Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages,” *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.
- [32] H. B. Mann and D. R. Whitney, “On a Test of Whether One of Two Random Variables is Stochastically Larger than the Other,” *Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [33] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [34] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [35] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.